

UNIT-III

ACCESS CONTROL AND SECURITY

NETWORK ACCESS CONTROL (NAC)

- * It is an umbrella term for managing access to a network.
- * NAC Authenticates users logging in to the network and determines what data they can access and actions they can perform.
- * NAC also examines the health of the user's computer or mobile device.

Elements of a Network Access Control System

NAC Systems deal with three categories of components:

1) Access requestor (AR)

- * The AR is the node that is attempting to access the network and may be any device that is managed by the NAC System, including workstations, servers, printers, cameras and other IP-enabled devices.
- * It is also referred to as supplicants, or simply clients.

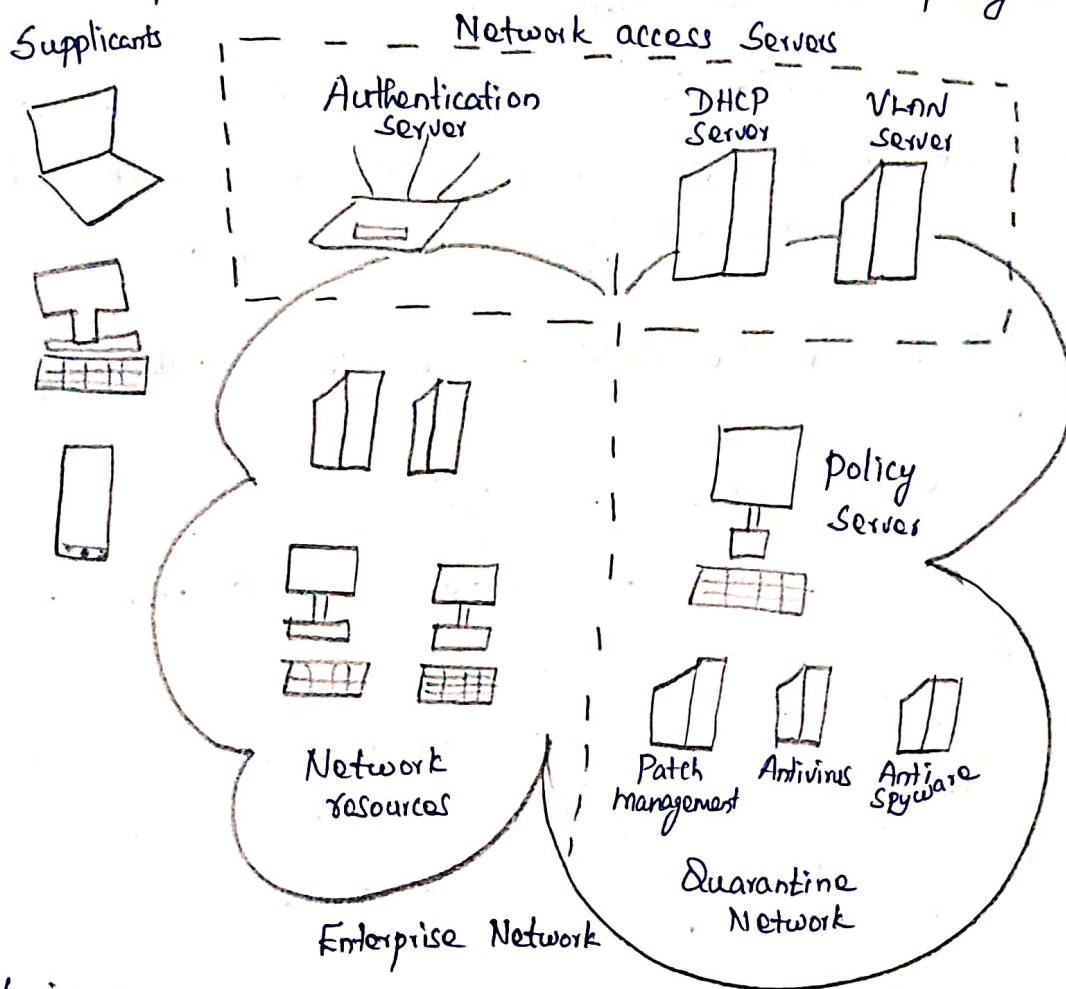
2) Policy Server

- * Based on the AR's posture and an enterprise's defined policy, the policy server determines what access should be granted.
- * The policy server often relies on backend systems, including antivirus, patch management or a user directory, to help determine the host's condition.

3) Network access Server (NAS)

- * The NAS function as an access control point for users in remote locations connecting to an enterprise's internal network.
- * It is also called a media gateway, a remote access server (RAS), or a policy server.

- * NAs may include its own authentication services or rely on a separate authentication service from the policy server.



- * It is a network generic access diagram.
- * A variety of different ARs seek access to an enterprise n/w by applying to some type of NAS.
- * The first step is to authenticate the AR.
- * Authentication typically involves some sort of secure protocol and the use of cryptographic keys.
- * Authentication may be performed by the NAs.
- * Authentication takes place between the Supplient and an authentication server that is part of the policy server or that is accessed by the policy server.
- * The authentication process serves a number of purposes.
- * It verifies a Supplient's claimed identity.
- * The authentication exchange may result in the establishment of session keys to enable future secure communication b/w the Supplient & resources

on the enterprise n/w.

- * The policy server or a supporting server will perform checks on the AR to determine if it should be permitted interactive remote access connectivity.

- * Once an AR has been authenticated and cleared for a certain level of access to the enterprise network, the NAS can enable the AR to interact with resources in the enterprise n/w.

Network Access Enforcement Methods.

- * The Actions that are applied to AR's to regulate access to the enterprise network.

- * Many vendors support multiple enforcement methods simultaneously.

- * The following are common NAC enforcement methods.

IEEE 802.1X

- * This is a link layer protocol that enforces authorization before a port is assigned an IP address.

- * It makes use of the Extensible Authentication Protocol for the authentication process.

Virtual Local Area networks (VLANs)

- * The enterprise n/w consists of an interconnected set of LANs, is segmented logically into a number of Virtual LANs.

- * The NAC system decides to which of the n/w's VLANs it will direct an AR, based on whether the device needs security remediation

Firewall

- * It provides a form of NAC by allowing or denying n/w traffic b/w an enterprise host and an external user.

DHCP management.

- * It is an internet protocol that enables dynamic allocation of IP addresses to hosts.

* A DHCP Server intercepts DHCP requests and assigns IP addresses instead.

* Thus NAC enforcement occurs at the IP layer based on subnet and IP assignment.

Extensible Authentication Protocol

* It is defined in RFC 3748, acts as a framework for n/w access and authentication protocols.

* EAP provides a set of protocol messages that can encapsulate various authentication methods to be used b/w a client and an authentication server.

* EAP can operate over a variety of n/w and link level facilities, including point-to-point links.

Authentication Methods

* EAP supports multiple authentication methods.

* It is referring to EAP as extensible.

* EAP provides a generic transport service for the exchange of authentication information b/w a client system and an authentication server.

* The basic EAP transport service is extended by using a specific authentication protocol or method, that is installed in both the EAP client and the authentication server.

What is EAP?

It provides a basic request/response protocol framework over which we implement a specific authentication algorithm, so called EAP mtd. Commonly used EAP methods.

- EAP - MD5

- EAP - TLS → How the TLS protocol is encapsulated in EAP msg.

- EAP - TTLS

- EAP - PEAP - Protected Extensible Authentication Protocol.

Components in an EAP Conversation

Supplicant - It could be a SW (installed or built-in) running on your windows m/c or a built in SW on your smart phone.

* Some one who wants to access to the n/w and protect to gate for n/w access is supplicant.

Gate / Authenticator - a device which provides a path to the n/w or the n/w resources.

* This gate / device can be instructed to via the allowed denied access to the n/w.

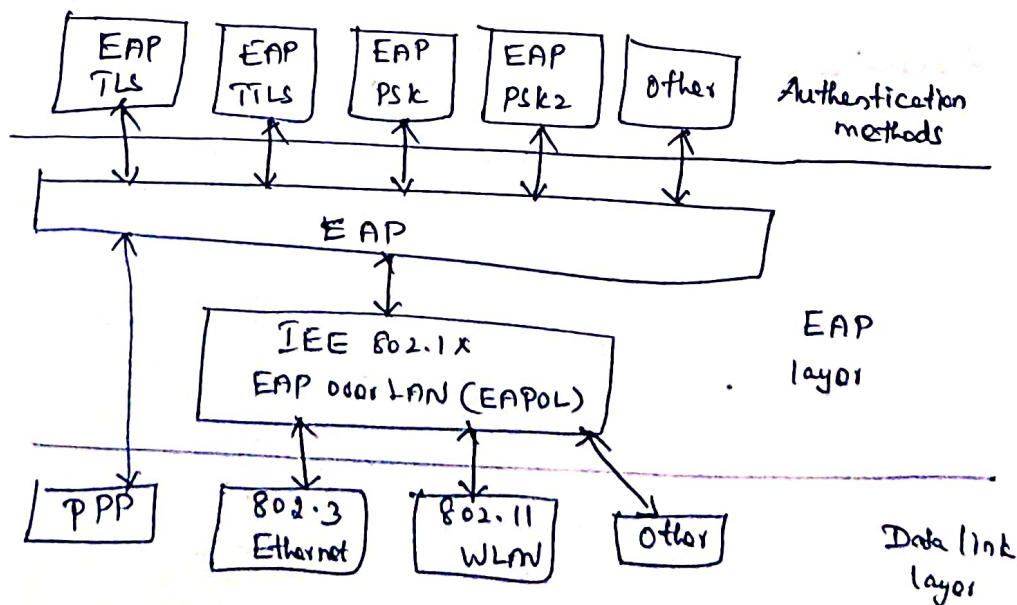
Authentication Server → decision.

802.1x - standard that was built to govern the way EAP authentication methods.

EAP over Lan's.

Supplicant — Authenticator — Authentication Server

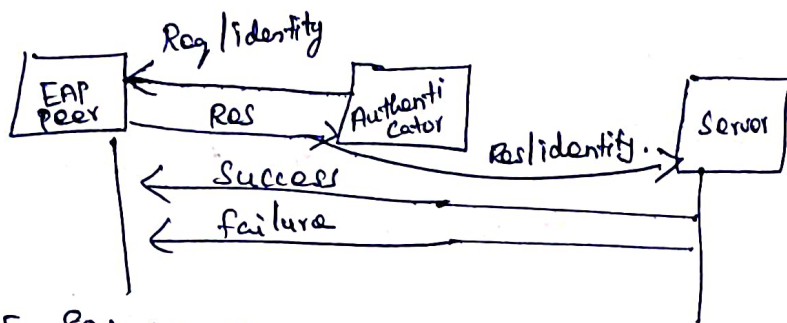
- 1) Agent - It request to access the n/w.
- 2) Control to physical access to n/w based on the authentication status of the client.
- 3) It request identify from the client authentication status of the client.



* EAP is a flexible transport protocol used to carry arbitrary authentication information.

* Originally created for PPP, EAP was expanded to wired and wireless LAN

* EAP is media-independent, but typically runs over data link layers such as PPP, IEEE 802.3 wires or 802.11 wireless media.



IEEE 802.1X Port-Based Network Access Control

* It was designed to provide access control functions for LANs

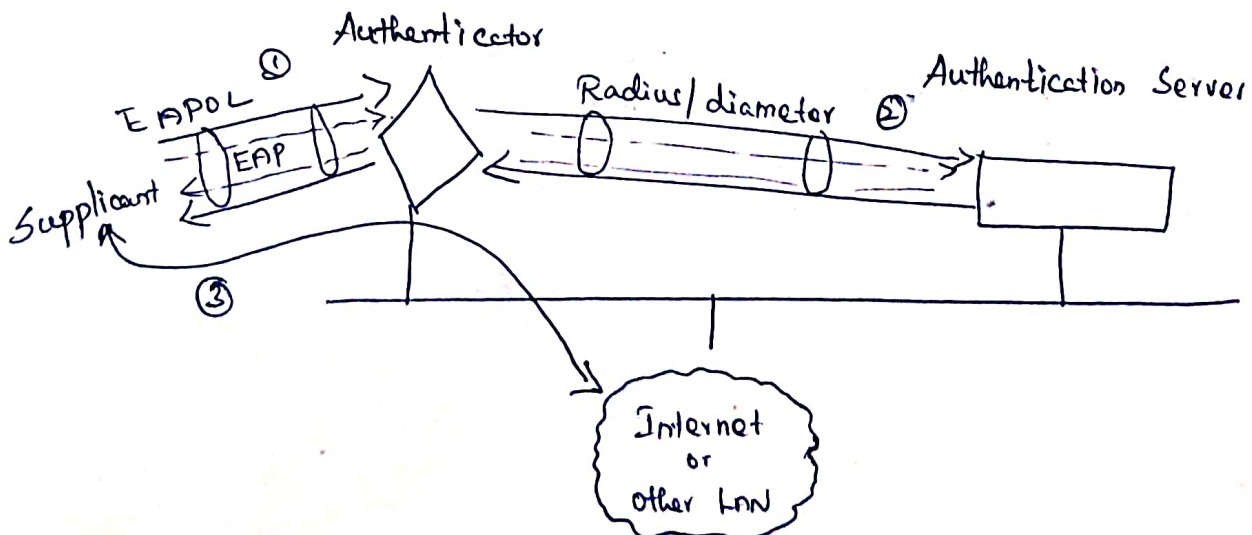
* It is a port based authentication

* which uses protocol EAPOL which is known as EAPOL (or) Extensible Authentication Protocol over LAN.

* Used to transport EAP packets b/w Supplicant and an authenticator over LAN.

* Provide access control function for LAN's

802.1X Components



- * EAP data is first encapsulated in EAPOL frames b/w the Supplicant and Authenticator, then re-encapsulated b/w the Authenticator and the Authentication Server using RADIUS or Diameter.

Client / Supplicant

- * The Client is the end user workstation or device that requests access to the LAN and it responds to req from the Switch.
- * The Client must run 802.1x Compliant Client SW.

Authenticator:

- * Physically Controls access to the n/w based on the authentication status of the Client.
- * It is the intermediary b/w the Client and the Authentication Server such as RADIUS Server.
- * When the Switch receives the EAPOL frames it relays them to the Authentication Server.

Authentication Server

- * The server that performs the actual authentication of the request.
- * It sends a reply back to the switch as to whether or not the authentication request is valid and if the client is validated to access the n/w & other switch services.

Conditions for 802.1x

- * If the PC is configured for 802.1x. Switch is not configured.
- * PC abandons the protocol & communicates normally.
- * Switch is 802.1x → PC does not support.
- * Switch port remains in unauthorized state and will not forward traffic to client PC.

* 802.1x switch port begins in unauthorized state & either the PC or switch has to initiate 802.1x

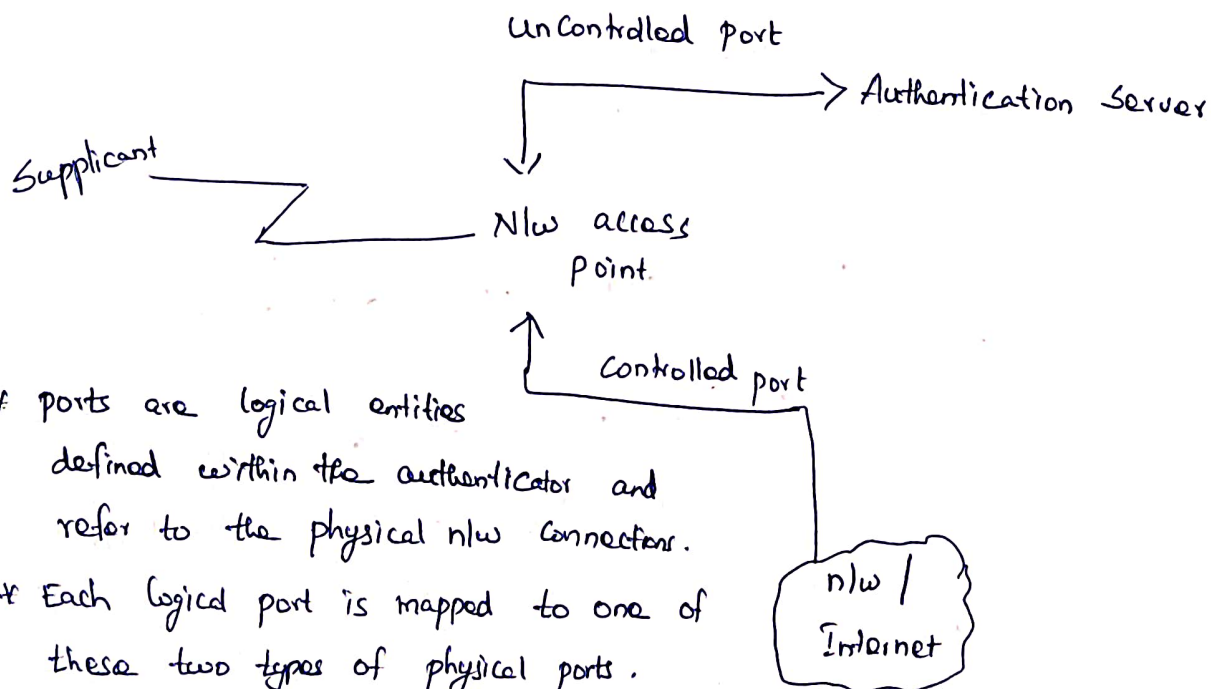
802.1 States

Force-authorized

- * The port is forced to authorize any connected Client.
- * No authentication is necessary.
- * This is the default state when 802.1x enabled.

Force-unauthorized

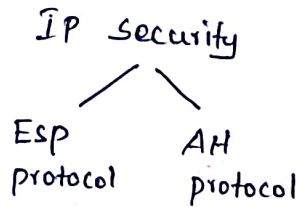
- * The port is forced to never authorize any connected Client automatically.
- * The port is moved from unauthorized state to authorized state.



- * ports are logical entities defined within the authenticator and refer to the physical n/w connections.
- * Each logical port is mapped to one of these two types of physical ports.
- * An Uncontrolled port allows the exchange of protocol data units b/w the Supplicant & the Authentication Server.
- * Controlled port exchange b/w the Supplicant & other systems on the n/w.

IP Security

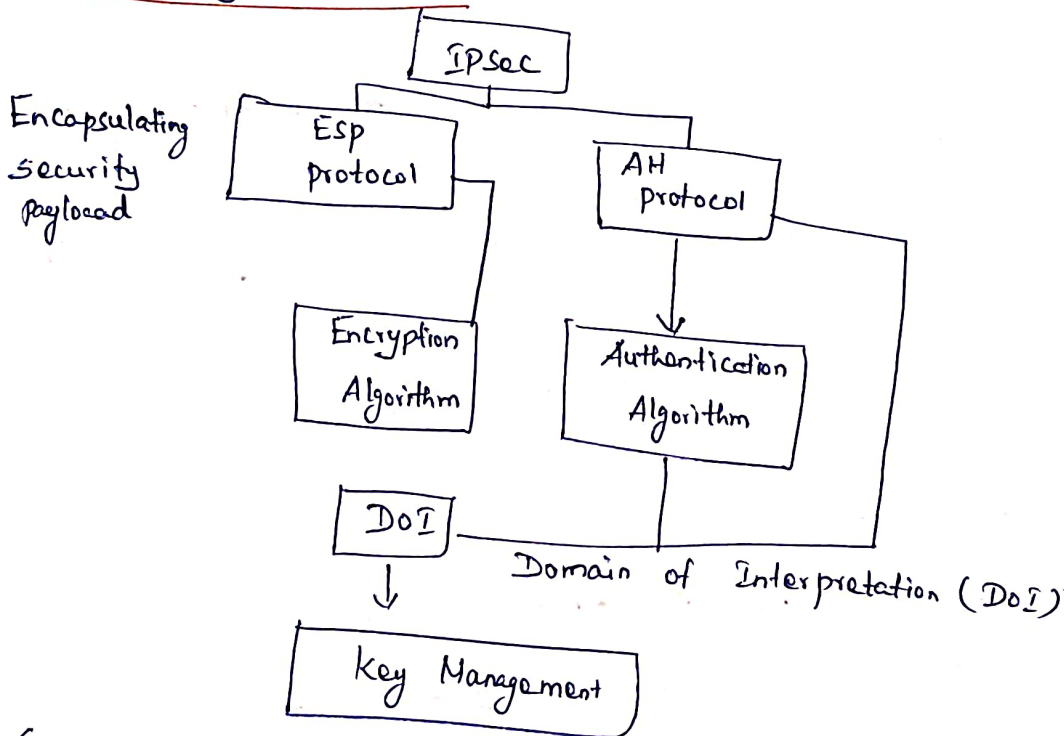
- * IP protocol itself doesn't have any security features.
- * It is a framework that helps us to protect IP traffic on the n/w layer.



Services:-

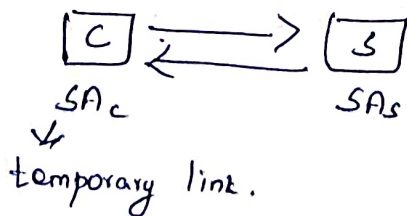
- Confidentiality - ESP
 - Authentication
 - Integrity
- } Implemented in AH

IP Security Architecture



Security Association (SA)

- Communication b/w Client & Server.
- One way Communication



- * Two Security Association should be established.
- * All the Security Associations is maintained in the SA db.

Security Association Parameters.

1) Security Parameter Index (SPI)

- unique no. will be given to the particular Association
- It will be carried both the protocols either in ESP or AH.

2) IP destination Address.

- Server Address (receiver address)

3) Security Protocol Identifier

- AH or ESP

SAD (Security Association Database)

- SPI
- Sequence number Counter

- bandwidth in the n/w msg will be divided into different packets.

- Each packet will be given one unique no. & transmitted to the receiver..

- Receiver side it will collect all the packets and according to the number.

- Sequence number overflow

- Where we have to stop the message.

- If the sequence number reaches the particular threshold we can activate particular parameter.

- Anti replay Window

- Used to avoid the duplicate of the packets.



1st packet received put mark.

The number will be compared with the window.

— AH Information

* All the Signature algorithm, Authentication, Integrity.

— ESP Information

* Provide all the information about encryption algorithm & Authentication.

— Lifetime of SA.

* The period of validity of the Security Association.

* New Security will be associated with this.

— IPsec protocol mode

* AH and Esp

* 2 different modes

- Transport Mode
- Tunnel Mode

ESP

→ Implemented in 2 ways.

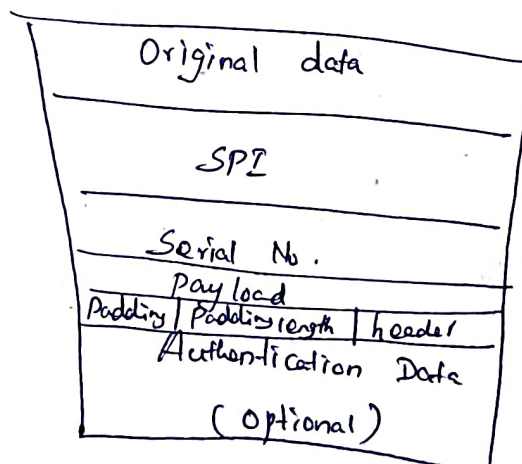
→ Esp with optional Authentication.

→ Esp with Authentication.

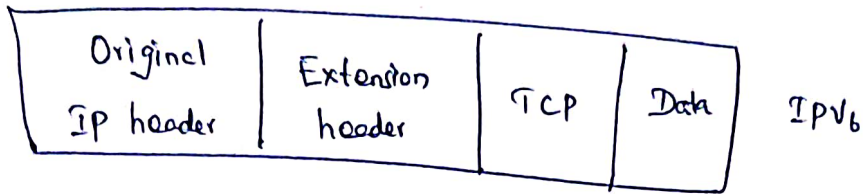
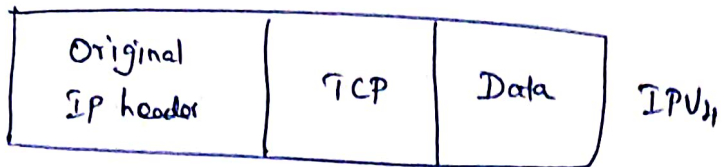
AH

* Authentication Along with Integrity.

Packet format of Esp.

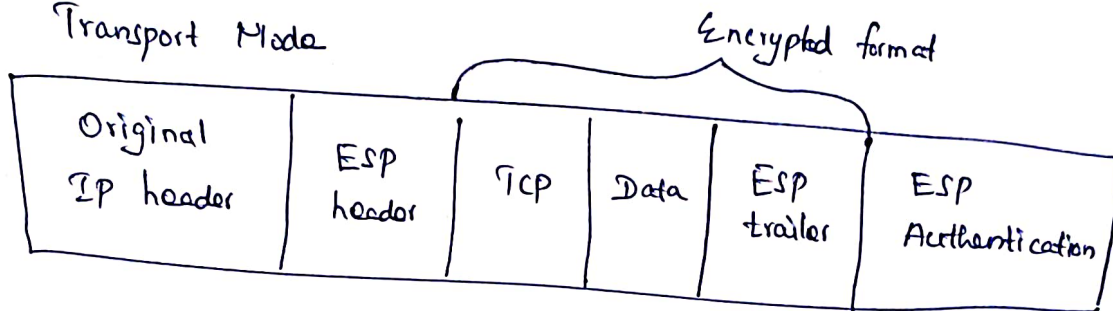


IP header format (Version 4 & 6)

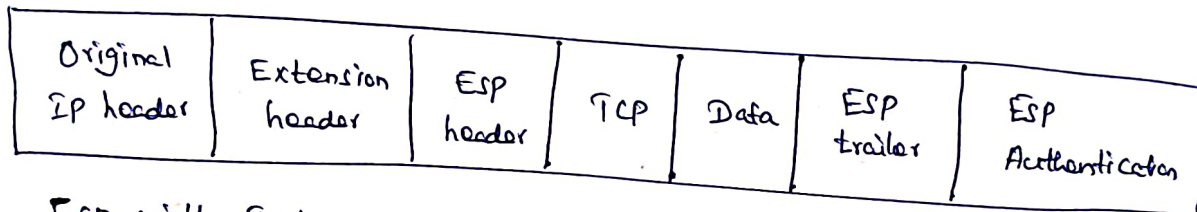


ESP with IPv4

Transport Mode

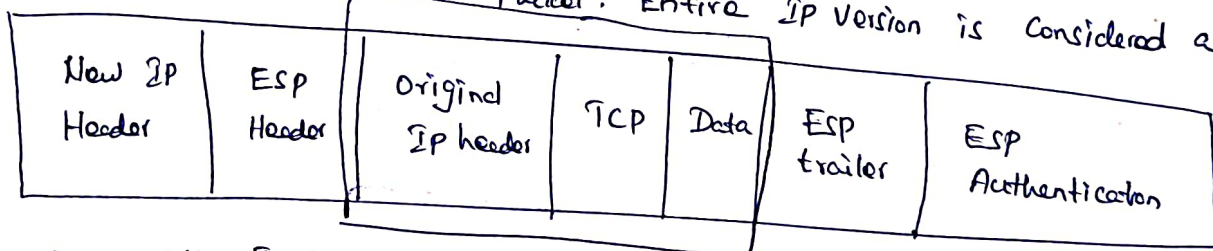


ESP with IPv6 Transport Mode

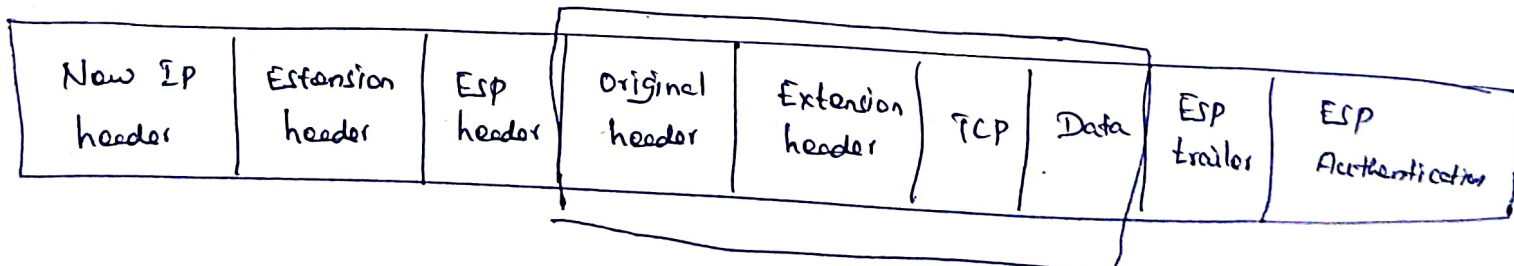


ESP with IPv6

Tunnel mode . Inner Packet. Entire IP Version is considered as inner packet.



ESP with IPv4 in Tunnel Mode

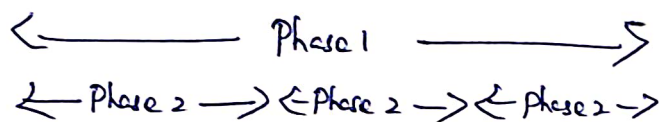


Internet Key Exchange (IKE)

- * It performs its job using ISAKMP framework using 2 phases.
- * Before we can protect any IP packets, we need two IPsec entity that build the IPsec tunnel.
- * To establish the IPsec tunnel, we use a protocol called IKE.
- * 2 phases are

IKE Phase 1 - Mutual authentication & session keys.

IKE Phase 2 - use results of phase 1 to create multiple association between the same entities.



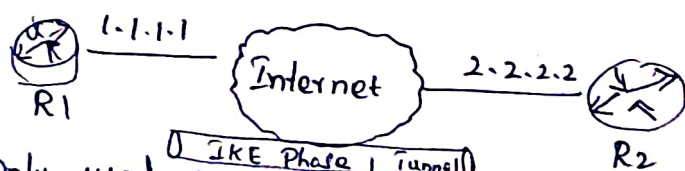
IKE Phase 1

* It is used to negotiate ISAKMP policy by exchange 5 parameters referred to as haglo.

* The collection of parameters that the two devices will use is called a SA (Security Association)

* This is also called the ISAKMP tunnel or IKE phase 1 tunnel.

Example of two routers that have established the IKE phase 1 tunnel:



* Only used for management traffic

* This tunnel is used as a secure method to establish the second tunnel called the IKE phase 2 tunnel or IPsec tunnel and for management traffic like keepalives.

Authentication Header

Packet format is

Next header	Padding length	Reserved
SPI		
S.No		
Authentication Data (Integrity Check Sum)		

Transport Mode : IPV₄

Original IP header	AH	TCP	Data
--------------------	----	-----	------

IPV₆

Original IP header	Extension header	AH	TCP	Data
--------------------	------------------	----	-----	------

Tunnel Mode : IPV₄

New IP header	AH	Original IP header	TCP	Data
---------------	----	--------------------	-----	------

IPV₆

New IP header	Extension header	AH	Original IP	TCP	Data
---------------	------------------	----	-------------	-----	------

Steps in phase 1

The main purpose of IKE phase 1 is to establish a secure tunnel that we can use for IKE phase 2.

We can break down phase 1 in three simple steps.

Step 1: Negotiation: The two peers will negotiate about the following items:

- * Hashing (MD5, SHA)
- * Authentication (Pre-Shared keys, DSS, etc)
- * DH (Diffie Hellman) parameters.
- * Lifetime
- * Encryption (DES, 3DES, IDEA)

Step 2: DH key Exchange: Both entities use the DH group that they negotiated to exchange keying material. The end result will be that both peers will have a shared key.

Step 3: Authentication: The two peers will authenticate each other using the authentication method that they agreed upon in the negotiation.

The end result is a IKE phase 1 tunnel (ISAKMP tunnel) which is bidirectional.

Modes of Phase 1

* The three steps above can be completed using two different modes.

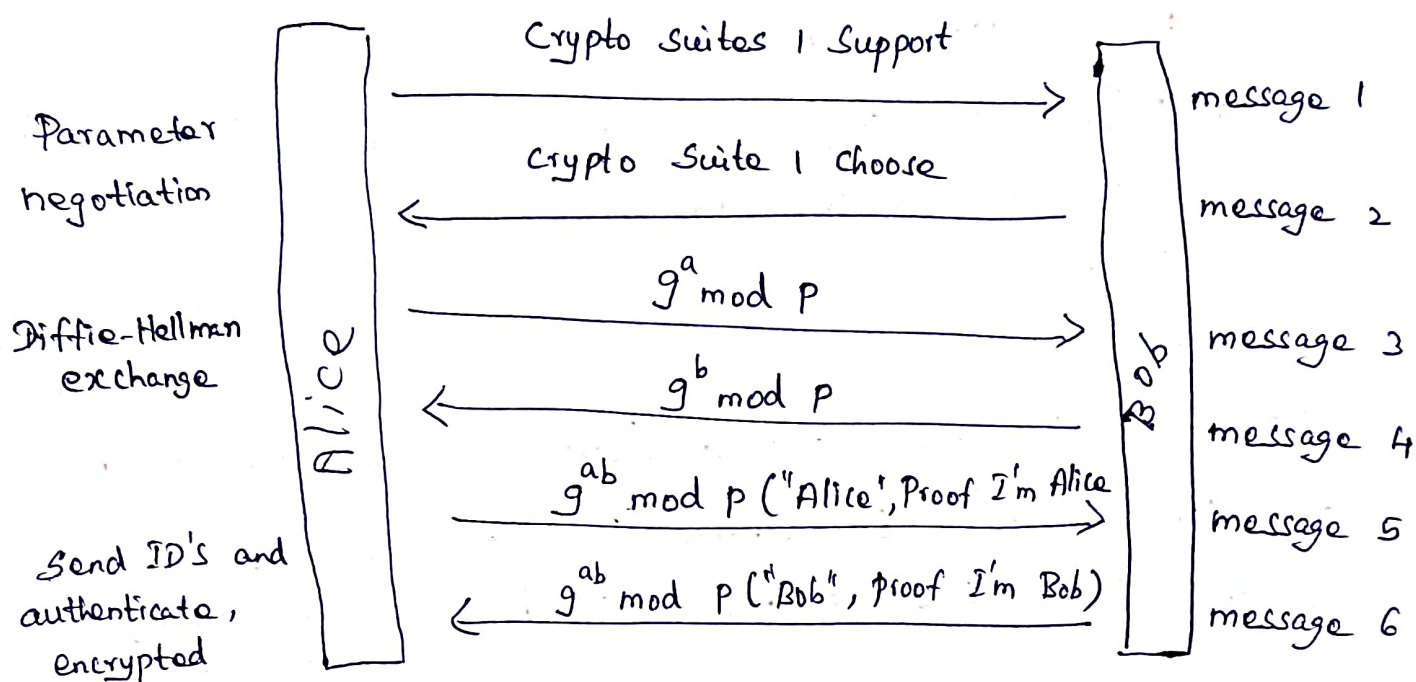
- Main mode
- Aggressive mode

* Main mode uses six messages while aggressive mode only uses three messages.

* Main mode is considered more secure.

IKE Main Mode

* Allows ability to hide end-point identifiers and to select crypto algorithms $\Rightarrow$ requires 6 messages.



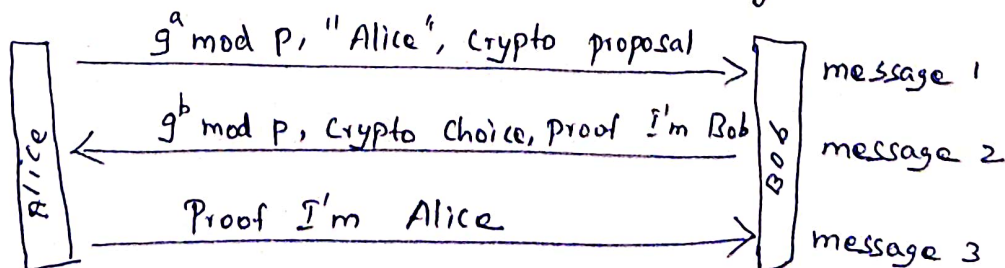
* The first two messages negotiate policy:

* the next two exchange Diffie-Hellman public values and nonces necessary for the exchange.

* and the last two messages authenticate the Diffie-Hellman Exchange.

IKE Aggressive Mode

* End-points ID not hidden $\Rightarrow$ Requires only three messages.



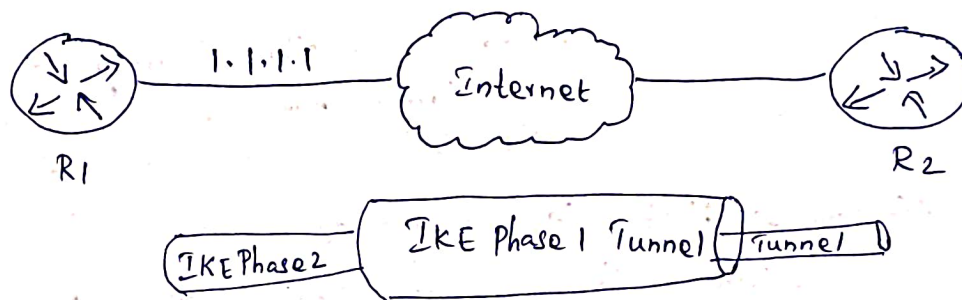
IKE Authentication Methods.

- 1) Original Public key Encryption (Seperately encrypt each field with other sides public key)
- 2) Revised Public key Encryption (Encrypt session key with public key, Use session key to encrypt the rest)
- 3) Public key Signature.
- 4) Pre-Shared Secret key.

4 Methods $\times$ 2 Modes = 8 Variants of Phase 1

IKE Phase 2

Example of two router Completed phase 2:



* Once IKE Phase 2 is completed, we have an IKE phase 2 tunnel (or IPsec tunnel) that we can use to protect our user data.

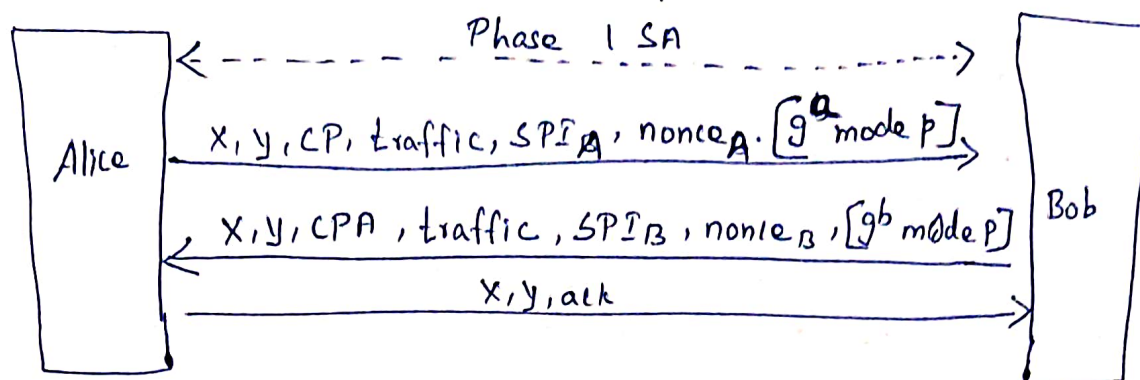
* IPsec (AH or ESP) SA can be set up in Phase 2

=> Negotiate crypto parameters, another optional DH (for Perfect forward Secrecy), traffic selectors.

* Traffic Selector = IP address or mask, IP Protocol type, and TCP/UDP port.

* If traffic selector is wider than the acceptable, the request will be refused.

* Phase 2 is also known as quick mode.



* X = pair of cookies generated in phase 1

* Y = a 32-bit number to distinguish different phase 2 sessions.

* CP = Crypto Proposal, CPA = Crypto Proposal Accepted

* X and Y are in clear text of the phase 2 messages are encrypted and integrity protected.

Web Security Considerations:- $\rightarrow$ It deals with the Security of data over internet / network or web or while it is being transferred to the Internet.



Attacker $\rightarrow$ Hackers (threat, modify)

$\therefore$ Security is required for websites. It is always prone to Security threats / risks.

Security Considerations

- 1) Updated Softwares
- 2) Beware of SQL Injections - inserting / update / delete
- 3) Cross site scripting (xss) - eg: Forms (google forms)
- 4) Error message
- 5) Data Validation
- 6) Passwords

* Hacking of websites may result in theft of important customer data.

* Therefore, Security Consideration is needed in the context of Web-Security.

1) updated Softwares.

* Mandatory to update Software

eg: Anti virus Softwares.

2) Beware of SQL Injection!.

* When some one send a query ^{to the website}, this query will be a rogue code.

* This rogue code is send to the website, then executed and modify in the database / tables.

3) Cross site Scripting (xss)

* Attacker can inject Client side script into your webpage.

* eg: Submission of forms.

4) Error Message.

* Error messages are generated to give the information to the users.

* While users try to access the websites and some error messages are generated due to one or other reason and you should be very careful while providing the information to the users.

eg: Login Attempt.

5) Data Validation

* It should be perform both on Server side and Client side.

* If ~~we~~ ^{do} provide data validation on both sides authentication will be provided give us authentication.

6) Passwords.

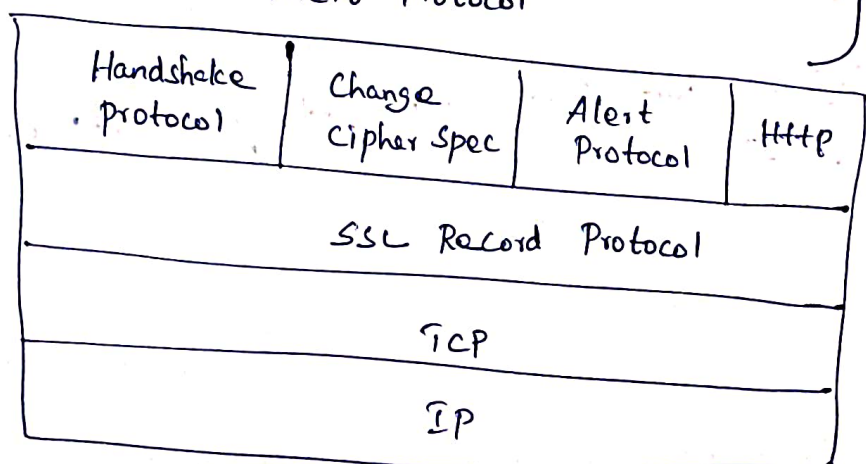
- * The usage of passwords should be enforced
- * The minimum length of these password is 8 Characters.
- * It should be the combination of both upper & lower case letters & some special characters.

Secure Socket Layer

- * Provides security to the data over the internet. i.e. data transferred between web-browser and web-server.
- * SSL is implemented with the sub-protocols.

- SSL Record Protocol
- Handshake Protocol
- Change Cipher Spec Protocol
- Alert Protocol

} Protocol stack of SSL



* Two important parameter

- 1) Connection State Parameter
- 2) Session State Parameter

Session State and Connection State Parameters.

Session State Parameter

1) Session Identifier

- * It is 8 bit number which identifies the server

2) Peer Certificate

- * X.509 Certificate will be ensured authenticity.

3) Compression Method

- * optional parameter

- * either we can use it or drop it

4) Cipher Spec or Suite

- * MAC, usage of Hash

5) Master Secret

- * It is a Secret key, which is used in the session

- * 48 byte and it is the SSL Version 3

6) Is Resumable!

- * Flag - Yes or No

- * whether the session is Resumed or start a new session

Connection State Parameters

1) Server and Client in random numbers.

- * byte sequence associated with Client / Server

2) Server write MAC Secret

- * MAC Generated by Server

3) Client Write MAC Secret

- * MAC Generated by Client

4) Server write key

- * Shared Secret key

- * secret key used to Conventional encryption by the Server.

5) Client Write key

- * Shared Secret key by the Client.

6) Initialization Vector

- * just like a buffer / dummy bits

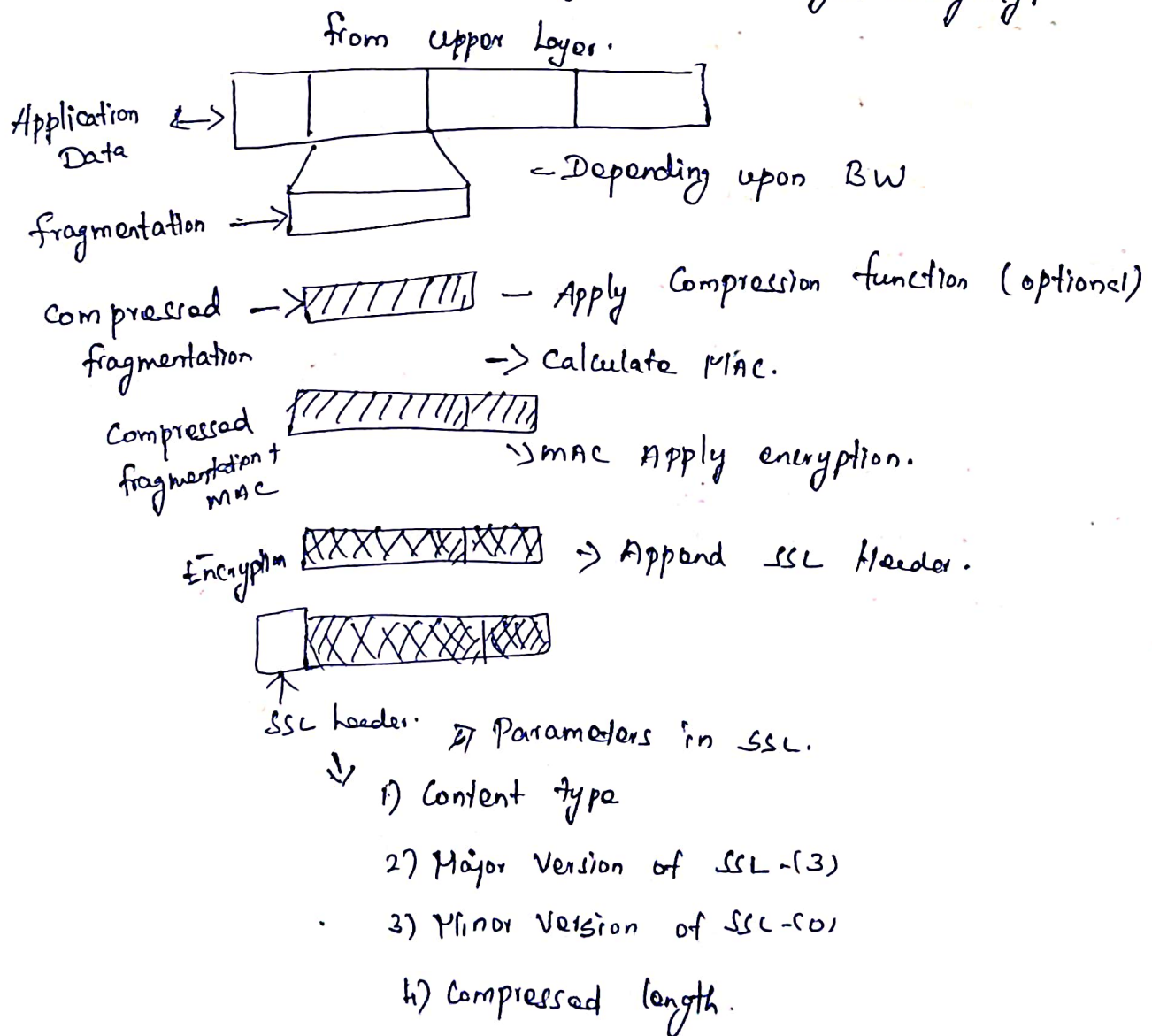
7) Sequence Number

* Generated and appeared each and every packet through the transmission.

* Based upon the bandwidth the data will be fragmented and the Sequence number is allocated for each and every fragment. Collect all the packets with the corresponds Sequence number.

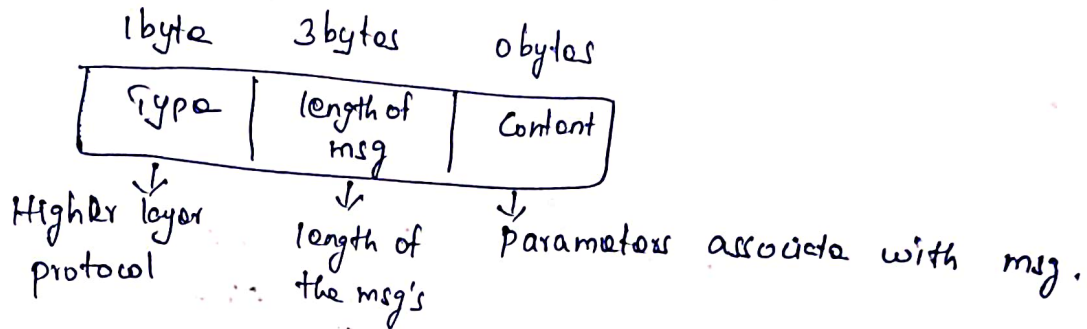
SSL Record Protocol

* Provides Confidentiality and Message Integrity.



Handshake Protocol

- * used to establish the session b/w client and server.
- * Negotiates the cipher suite
- * Exchanges the information for building cryptographic secrets.



Client

Server

Client hello. → Server hello ← } completes the 1st phase

Certificate msg ←
Server key exchange (PUS) ←
Certificate - Req ←
Server hello done ← } 2nd phase

Certificate →
client key exchange (PUC) →
Certificate verify → } 3rd phase

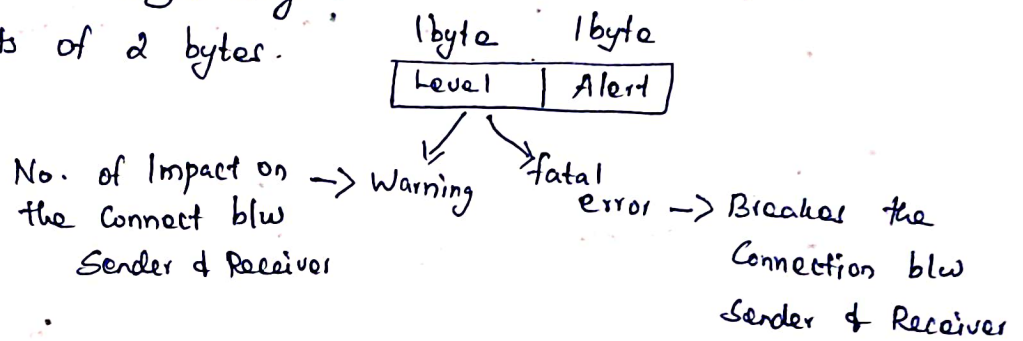
Change Cipher Spec →
Finished →
Change Cipher-Spec ←
Finished ← } 4th phase

Change Cipher Spec Protocol

- * It uses SSL Record Protocol
- * keeps the output of Record Protocol in Pending State unless handshake protocol is completed.
- * Converts Pending state to current state. msg is 1 byte
Pending State = Current State.

Alert Protocol

- * sends the alert messages only
- * Message consists of 2 bytes.



Alerts

unexpected message, bad record MAC, Decompression failure, Handshake failure, illegal Parameters etc. → These are fatal error Category

Other Alerts.

Close Notify, No Certificate, Bad Certificate, UnSupported Certificate, Certificate revoked, Certificate expired, Certificate Unknown etc.

Transport Layer Security :-

- * TLS was proposed by the Internet Engineering Task Force (IETF), an international Standards Organization.
- * TLS was derived from Secure Socket Layer (SSL)
- * The first version of TLS was published in 1999.
- * The most recent version in TLS 1.3 which was published in 2018.

What is Transport Layer Security (TLS)?

- * Transport Layer Security (TLS) is designed to provide security at transport layer.
- * TLS is used to create a secure connection between a client and a server.

What does TLS do?

- * TLS ensures Encryption, Authentication and Integrity.

* Encryption:

Hides the data being transferred from third parties.

* Authentication:

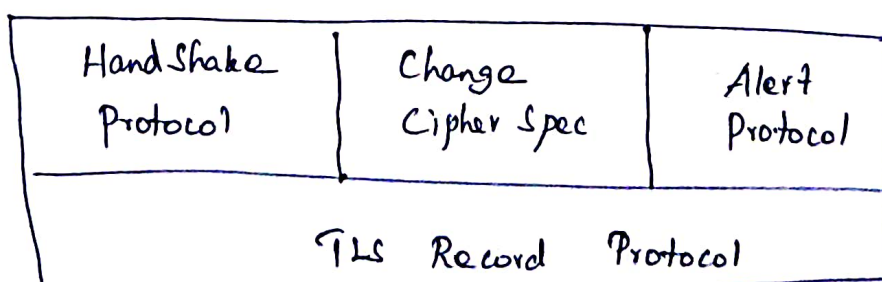
Ensures that the parties exchanging information are who they claim to be.

* Integrity:

Verifies that the data has not been forged or tampered with.

TLS Protocol Stack

- * The architecture of Transport Layer Security (TLS) involves several components and processes that work together to establish secure communication between clients and servers.

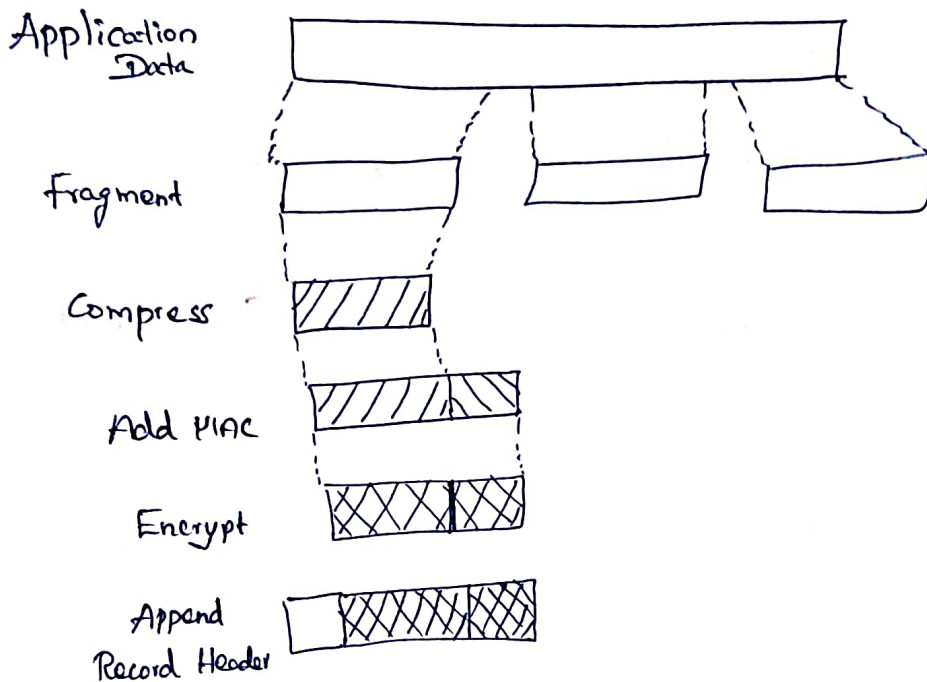


TLS Record Protocol

* TLS Record Protocol provides two services to TLS connection.

* Confidentiality

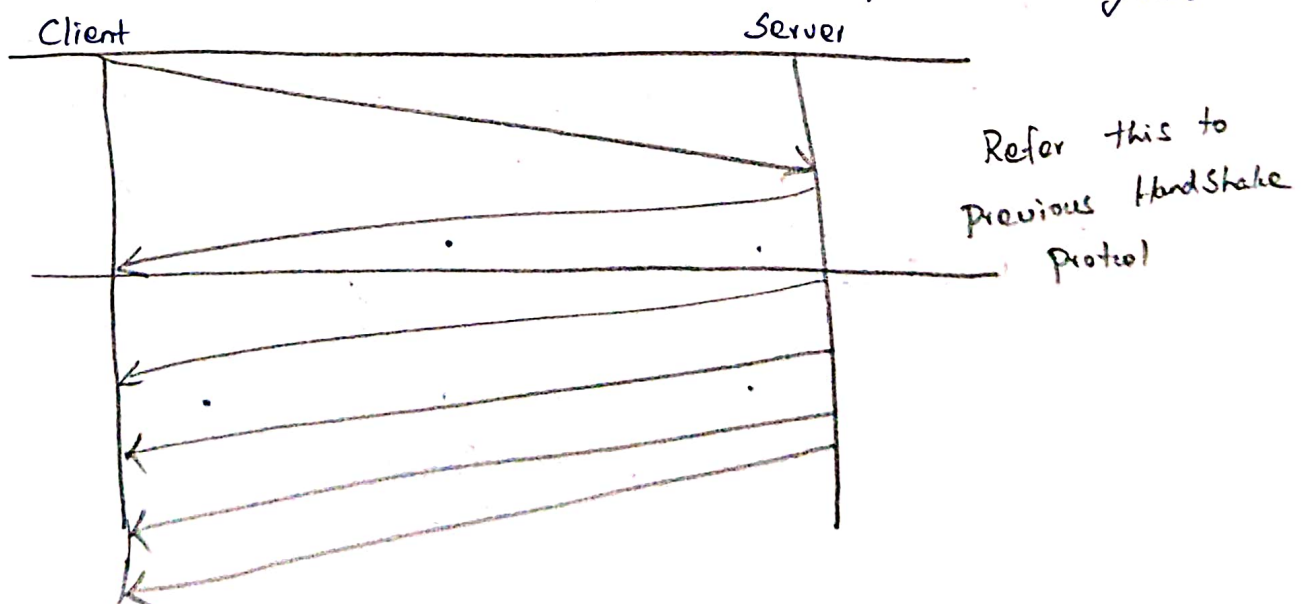
* Integrity



TLS Hand Shake Protocol

* This protocol allows the client and server to authenticate each other by sending a series of messages to each other.

* Handshake Protocol uses four phases to complete its cycle.

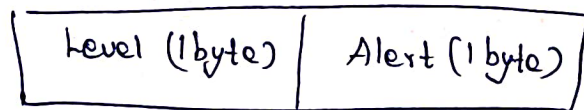


Change Cipher Spec Protocol

- * Change cipher protocol consists of a single message which is 1 byte in length and can have only one value.
- * This protocol purpose is to cause the pending state to be copied into the current state.

Alert Protocol:

- * Alert protocol is used to convey tls-related alerts to the peer activity entity.
- * Each message in this protocol contains 2 bytes.



- * In first byte it has 2 levels.
- Level 1: Warning alert. This alert has no impact on the connection between sender and receiver.
Ex: Certificate, Expired, No Certificate
- Level 2: Fatal Error. This alert breaks the connection b/w sender and receiver.
Ex: Bad record MAC, Handshake failure.
- * The second byte in the alert protocol describes the error.

Https Standard

- * HTTPS stands for "Hyper Text Transfer Protocol"

What is HTTPS?

HTTPS is a protocol, which is used for communication between

web browser and web server.

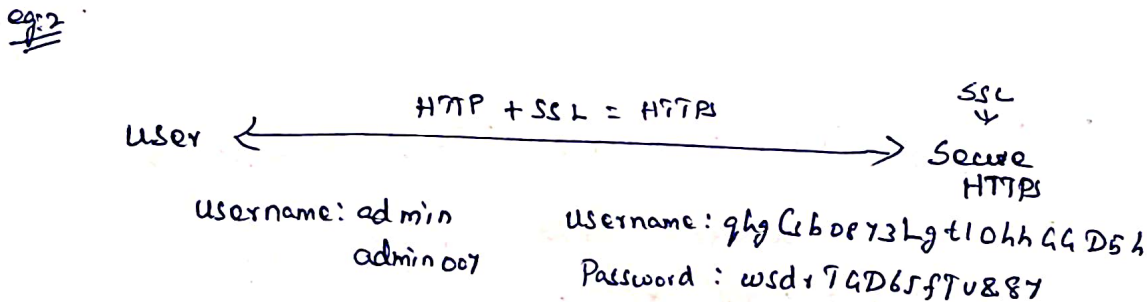
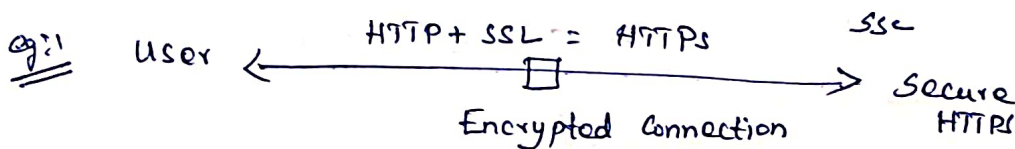
* HTTPS is secure version of HTTP.

Purpose of HTTPS:

* HTTPS provides the Confidentiality and Integrity of data between the user's computer and the website.

* HTTPS encrypt URL, username, password and sensitive information of user.

Working of HTTPS



Following elements are encrypted.

- URL of the requested document
- Contents of the document
- Contents of browser forms (filled in by browser user)
- Cookies sent from browser to server and from server to browser.
- Contents of HTTP header

What is the default port number of HTTPS?

443 is the default port number of HTTPS.

Introduction of HTTPS.

Is Search Engine uses HTTP or HTTPS?

* Search engine uses HTTPS

eg: Google, Bing, DuckDuckGo, Yandex

HTTPS Connection

1) Connection Initiation

2) Data Transfer

3) Connection Closure

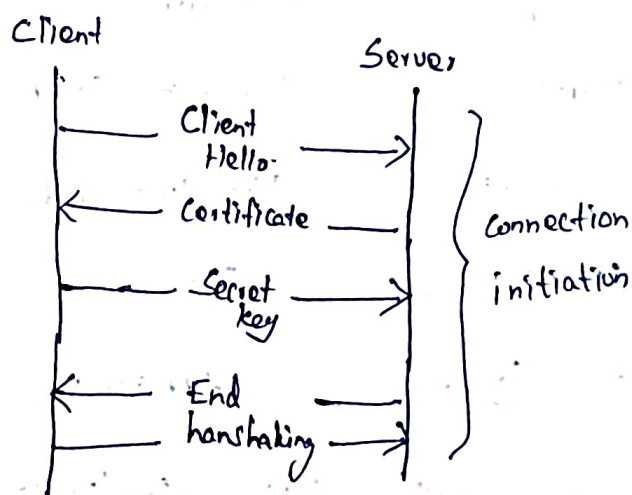
eg: for Connection Initiation

1) Client Hello to Server.

2) Digital Certificate shared by Server.

3) Secret key share with Server

4) End handshaking

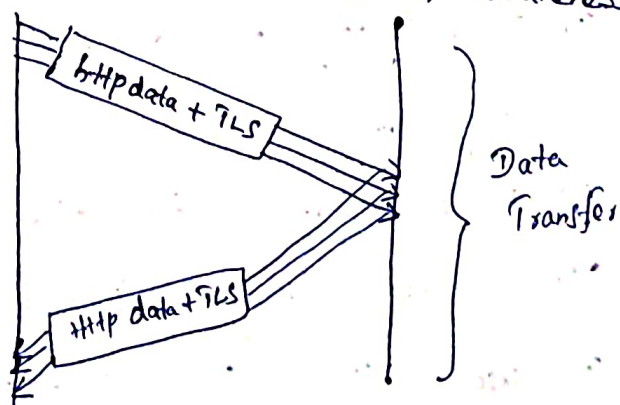


* We need to be clear that there are three levels of awareness of a connection in HTTPS.

- At the HTTP level

- At the level of TLS

- At the level of TCP



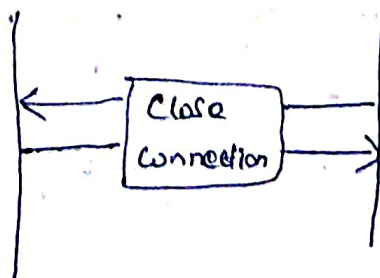
Data Transfer

* HTTP Request with TLS application data

Connection Closure

Connection closure should be done by three levels.

- HTTP level



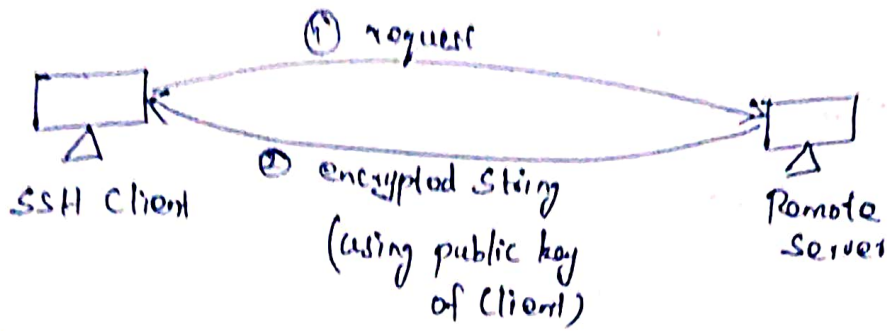
- TLS level
- TCP level

HTTP VS HTTPS

Parameter	HTTP	HTTPS
Acronyms	Hyper Text Transfer Protocol	Hyper Text Transfer Secure
Port Number	Default Port 80	Default port 443
URL	URL is start with http://	URL is start with https://
Security	Unsecure	Enhanced Security
Encryption	Does not support	Support
SSL Certificate	Not included	Included HTTP+SSL=HTTPS
Speed	Faster	Slower
Protocol layer	Application layer	Application & Transport Layer

Secure Shell (SSH) Application

- * It is a cryptographic network protocol for operating n/w services securely over an unsecured network.
- * It is a secure alternative to the non protected login protocols (like Telnet, rlogin) and insecure file transfer methods (like FTP)
- * It uses Client Server architecture.
- * It uses public key cryptography / asymmetric key cryptography to authenticate the remote server.
ie to verify its identity to the remote server.



- i) Client request to access the server. Server will check its files for the public key of the client.
- ii) Now, server will generate a random string and encrypt it using client's public key (and then this can only be decrypted by client's private key) and send it to client.
- iii) Client will decrypt the message and acknowledge it (i.e. send back to server).

Now server will know that yes this user ^{send} ~~was~~ the message to the client.

- * Thus the user is authentic and now, the client is verified.
- * After that, SSH creates a tunnel between client & server and we can pass our data (i.e. encrypted form) over this tunnel.
- * The encryption used by SSH is intended to provide confidentiality and integrity of data over an unsecured network (like internet)
- * SSH is used for accessing remote servers.

How this system can be used?

We have various types of SSH clients on our machines.

for MAC | Linux → terminal

Windows → PuTTY

SSH → Protocol for securely operating the N/w services over a unsecured channel.

→ Client / Server architecture

→ Asymmetric cryptographic used

→ designed as a replacement for Telnet and for other unsecured remote shell protocol.